安全自评报告

自评结论

知行已实现并验证赛题要求的权限分级、安全执行、审计与任务控制原型。系统适用于本机多模拟账户、单实例评审，尚不具备生产银行上线条件。本轮143项检查覆盖业务、HTTP、MySQL运营、身份数字人和前端连接状态。验证范围、未实现能力和残余风险如下，不以通过用例数替代安全性结论。

资产与信任边界

保护对象包括模拟余额、持仓、卡片状态、订阅协议、预约预算、定时任务与审计。外部输入来自用户自然语言、可选模型tool_calls及HTTP请求。模型输出始终是不可信提案。唯一可执行能力来自固定工具注册表，不包含shell、代码解释器、网络浏览或任意文件读写工具。

用户确认窗展示完整工具参数、操作详情和风险原因。强验证绑定当前会话、唯一步骤、参数摘要、一次性随机token和验证码，并检查180秒时效。旧步骤、旧token、取消后重放或其他浏览器会话均不应产生新的扣款。

权限与累计金额

级别	操作	控制
绿色	余额、流水、账单、产品查询、模拟问卷等	自动执行并记录工具结果
黄色	累计≤1000元转账与定时转账、取消订阅、新卡申请、日限额调整等	展示全部参数并取得确认
红色	累计>1000元资金承诺、理财申购赎回、挂失补发、解冻	密码及模拟一次性验证码

累计按北京时间自然日计算，计入已完成转账及当日新授权定时承诺，使用模拟汇率折人民币，确认时重新评估。已展示为红色的步骤不降级。生日后续预约只能引用当前DAG中已获授权的预留，不单独开放无预算预约。

三次强验证失败锁定模拟账户；单笔超过50000元或10分钟内已有五次资金承诺触发锁定。锁定后不会通过新建会话恢复写权限。生产的累计窗口、交易限额与解锁流程应由银行风险策略确定。

核验措施与证据

风险	措施	测试
注入越权	模式检测、固定工具与参数白名单、写操作意图匹配	17、19、38
负数、NaN、布尔金额	正数、有限数值、两位小数与币种校验	18、20、44
确认绕过	未确认不扣款，理财及大额强验证	02-16

风险	措施	测试
重放与跨会话	随机步骤ID、token、状态机、Cookie归属	12、13及HTTP
高频及连续失败	账户级安全锁定	15、45
虚假成功	以工具回执及余额、持仓、卡片、订单状态核验	11、32、33、36
链路部分失败	依赖失败停止后继，快照回退	36、40
状态变化与竞态	服务请求串行化、核心互斥、版本冲突暂停	37及HTTP
定时重复	已执行状态及持久化、重复推进幂等	34、43及HTTP
Web攻击	CSRF、同源检查、请求体限制、静态路径边界、CSP	HTTP测试
结果编造	只读工具、数值直接来源于业务数据，浮动收益保持空值	26、27

注入模式只能识别部分表达。真正的执行边界是工具与参数校验、用户确认和身份因子，不能宣称关键词过滤可防全部Prompt注入。

审计与恢复

审计使用SHA-256链接前一条记录，保留操作、风险、参数摘要、步骤依赖、执行成败与核验结果。密码和验证码不写入审计，收款人与备注在新执行记录中掩码处理。失败、取消、注入与人工接管也有事件。完整性测试验证单进程事件链，未提供外部可信锚、签名或WORM存储，攻击者若拥有审计文件写权限或数据库管理员权限仍可重算整条链。MySQL模式按自增序号恢复审计，支持相同时间戳，且业务状态、审计与运营请求同事务提交。

沙箱回退恢复账户与预约数据，但保留审计事件。若其他会话或定时任务改变状态，拒绝旧快照自动覆盖并暂停待人工处理。真实已结算转账不能用快照回退，须由银行侧实施有授权的冲正或补偿。

人工接管会按唯一审计来源生成MySQL复核工单和运营事件，经理可分派、处理、解决，但不会向外部客服发送消息。

已知风险清单

编号	风险及影响	后续措施
R01 高	模拟验证码直接显示于同一页面，通用密码已公开，无真实独立身份因子	接银行MFA，独立通道挑战与用户凭证
R02 高	已实现本机注册与账户隔离；演示身份仍共享，未接生产人员目录、真实开户及租户IAM	生产实名与岗位授权，关闭共享演示入口
R03 高	MySQL已提供本地状态、审计和指标原子提交，但未接银行清算幂等和提交确认丢失对账；JSON兼容模式仍非跨文件事务	生产事务账本、外部幂等业务号及对账任务
R04 中	审计可被具备本地权限者重写，写入异常处理仍需加强	不可变存储、签名锚、写前日志及故障演练

编号	风险及影响	后续措施
R05 中	模式解析和小样本问卷覆盖有限，复杂省略或指代可能无法理解	补意图评测集，模糊实体强制澄清
R06 中	订阅同名匹配可能误识别，非真实商户协议	协议ID匹配、人工复核、银行授权凭证
R07 中	模型开启时必要模拟上下文会传输至DeepSeek	真实接入前脱敏、最小化上下文、合约与数据出域审查
R08 中	定时任务演示支持正常重启幂等，非银行级恰好一次	银行幂等流水号、持久化授权凭证及清算确认
R09 中	静态模拟卡当日用量不跨日归零，长时间运行需重新初始化	按业务日归集限额和额度账本
R10 中	生日订单价格、地址、库存未连真实商户	接真实库存、地址确认、补偿取消与资金冻结接口
R11 低	原创SVG数字人与可选本机中文讲解不构成3D口型、多模态感知或实体机器人	独立评估真实设备、传感器与人机安全边界

凭据和数据声明

API密钥仅以进程环境或标准输入使用，未保存在源码、文档、前端或数据中，提交包排除.env及运行状态。演示金融数据为自建模拟集，不包含官方真实客户数据。账号、手机号和人物均是虚构测试标识，不可用于联系真实个人。团队仍需按实际参赛人员审核作品权属、AI辅助使用和隐私说明。

MySQL、运营权限和脱敏补充

MySQL密码仅由环境变量或启动脚本隐藏输入；原始密码不进入提交包。SQL使用参数化值，数据库名通过标识符白名单。只操作本项目zx_表。银行写操作事务失败时恢复业务内存、会话、审计尾部和修订号；发生版本冲突时拒绝写入，不切换文件模式继续执行。

仅显式选择演示身份可访问运营；注册客户不可访问运营API。演示运营默认领导只读，经理口令独立于数据库和银行交易口令，由服务端绑定浏览器会话角色。5次口令错误锁定60秒，经理角色不跨浏览器继承，重启后清除。运营写操作要求CSRF及正确工单版本；不能通过body中的role字段提权。运营角色不扩展30项金融工具的授权。

大屏与导出只返回聚合及字段白名单；不包含客户姓名、手机号、账号、证件号、设备IP、原始对话、API密钥和确认token。内部客户查询表字段掩码，工单说明写入前处理已知姓名、手机号、长账号和密钥表达。完整沙箱JSON内部仍含虚构联系人匹配标识，不宣称全库加密或生产数据匿名化。

新增残余风险：本机经理口令文件依赖操作系统访问权限；root数据库账号权限过宽，生产需专用低权限账号和凭据管理；设备与请求演练数据不代表真实经营；当前只支持单业务实例，关系投影非高吞吐量账本；轮询快照可延迟5秒，数据库故障时保留旧快照并标记过期。旧JSON模式仅供独立回归，不提供运营大屏。

新增故障、角色、脱敏、设备工单及恢复测试见evidence/mysql_ops_results.json；检查项数以该记录为准。真实设备接入、生产IAM、TLS外部入口、银行级备份演练与外部审计锚仍未实现。

审计格式及既有记录迁移

数据库迁移编号4将审计正文改用LONGTEXT精确保存序列化JSON，避免二进制JSON数字规范化影响哈希。早期35条SQL记录与保留的原始文件记录完整归档，并以已核对的摘要建立新链迁移锚；不宣称旧链在该格式转换后仍线性通过。新链启动时逐条严格校验，未来损坏拒绝启动，不能自动忽略。归档及银行状态未改动的核验见evidence/audit_storage_migration.json。

v4身份与数字人威胁边界

注册身份和零余额账户在同一InnoDB事务提交，失败恢复内存并回滚身份行。scrypt采用N=131072、r=8、p=1、随机16字节盐、32字节输出；登录错误统一反馈，未知用户也执行派生。账号5次错误及来源限流写入MySQL，浏览器更换不能清除账号计数。

登录使用随机HttpOnly、SameSite=Strict Cookie，数据库只存SHA256摘要。认证成功轮换浏览器Cookie和CSRF，空闲30分钟或绝对8小时失效，退出立即撤销。所有金融API校验登录和浏览器对话归属；业务主体只从服务端会话取得，未提供body切换账号功能。账户、流水、持仓、卡片、订阅、订单、预留、累计承诺、安全锁和定时任务按归属处理。注册昵称不被其他用户的联系人查询暴露。页面next使用严格白名单，静态HTML别名不绕过守卫。

数字人咨询返回已审阅的本地知识及编号，不生成真实银行政策。可选LLM咨询只允许选择已存在的主题ID；未知或失败给出范围提示。直接办理仍进入原工具、参数、权限和确认流程。数字人状态反馈不能作为执行成功证据。语音默认关闭，只选本机中文voice，不朗读金融详情；不启用摄像头或麦克风。客户端输出再次隐藏完整手机号、账号和内部归属字段。

新增残余风险：登录密码无自动找回或更改界面，管理员恢复需另行核验身份并撤销会话；登录会话数据库尚未磁盘加密；本机HTTP Cookie不含Secure属性，不能直接迁移公网；对话和未确认计划重启后清空；服务串行锁不支持多实例水平扩展；本地知识库需随业务政策审阅更新。共享演示身份可由所有本机体验者选择，只能用于非真实数据。对应44项新增隔离、失败、过期、退出和咨询执行边界检查见evidence/auth_digital_results.json。

业务快照回退保留验证失败计数和安全锁；强验证失败也推进状态修订号，防止其他任务的旧快照还原安全状态。失败回执计入运营失败请求，数字人显示安全提示。对应回归同时覆盖本账户取消、跨账户取消及审计归属。

浏览器业务上下文同时绑定用户ID及当前认证令牌摘要，混搭Cookie即使来自同一演示用户，也不能继承其他认证会话的对话或经理权限。前端重新获得焦点或从页面缓存恢复时复核身份，认证上下文变化则刷新页面。

强验证交互证据

确认窗明确风险、参数与模拟身份因子，验证码不是独立真实短信通道。新版登录认证不会替代交易授权。

